Schritt-für-Schritt: HTTPS mit selbstsigniertem Zertifikat einrichten

LF10b · LS02 – HTTPS und TLS konfigurieren · Anleitung · IT-3B · Schuljahr 2025/2026

> 🎯 **Ziel dieser Anleitung**
> Sie sichern den Webserver aus LS01 mit **HTTPS** ab: Sie erzeugen ein selbstsigniertes TLS-Zertifikat (RSA 4096, mit SAN), richten den HTTPS-VirtualHost ein, geben Port 443 frei, leiten HTTP auf HTTPS um und härten die TLS-Einstellungen. Voraussetzung: Ihr Server aus LS01 läuft (Apache erreichbar).

Teil A – Vorbereitung

Schritt 1 │ Snapshot anlegen (Sicherheitsnetz)

1. Fahren Sie die VM herunter: `sudo shutdown now`
2. In VirtualBox: VM auswählen → **Sicherungspunkte** (Snapshots) → **Erzeugen**.
3. Name: `vor_LS02_HTTPS` – so können Sie bei Problemen jederzeit zurück.
4. VM wieder starten und anmelden.

> ✅ **Gewohnheit**
> Vor jeder größeren Konfigurationsänderung einen Snapshot anlegen – das ist auch in der Praxis üblich (Backup vor Change).

Schritt 2 │ IP-Adresse prüfen

```
Aktuelle IP anzeigen (kann sich per DHCP ändern!)

ip a        # inet-Adresse des Adapters notieren, z. B. 192.168.10.137
```

Notieren Sie Ihre aktuelle IP – sie wird in Schritt 3 in das Zertifikat eingetragen:

Meine Server-IP heute	

Teil B – Zertifikat erzeugen

Schritt 3 │ Selbstsigniertes Zertifikat mit SAN erstellen

📖 **Warum SAN?**
Moderne Browser prüfen den **Subject Alternative Name (SAN)** im Zertifikat – nicht mehr nur den „Common Name". Ohne SAN-Eintrag mit Ihrer Server-IP meldet der Browser auch dann einen Fehler, wenn alles andere stimmt. Deshalb erzeugen wir das Zertifikat mit `-addext "subjectAltName=…"`.

Ersetzen Sie `[Server-IP]` durch Ihre IP aus Schritt 2 (der Befehl ist EINE Zeile – im Browser kann er optisch umbrechen; kopieren/tippen Sie ihn ohne Zeilenumbruch):

Zertifikat + privater Schlüssel (gültig 365 Tage, RSA 4096)

```
sudo openssl req -x509 -newkey rsa:4096 -nodes -days 365 -keyout /etc/ssl/private/netconsult.ke
```

Kontrolle: Zertifikat ansehen

```
openssl x509 -in /etc/ssl/certs/netconsult.crt -noout -subject -dates -ext subjectAltName
```

Bis wann ist das Zertifikat gültig (notAfter)?	
Welche IP steht im SAN?	

⚠️ **Privater Schlüssel**
Die Datei `netconsult.key` ist der **private Schlüssel** – wer ihn besitzt, kann sich als Ihr Server ausgeben. Er liegt deshalb in `/etc/ssl/private/` (nur für root lesbar) und wird **niemals** weitergegeben.

Teil C – Apache auf HTTPS umstellen

Schritt 4 | SSL-Modul aktivieren

Modul aktivieren

```
sudo a2enmod ssl                  # SSL/TLS-Modul einschalten
sudo systemctl restart apache2    # Apache neu starten
```

Schritt 5 | HTTPS-VirtualHost konfigurieren

Konfigurationsdatei öffnen

```
sudo nano /etc/apache2/sites-available/default-ssl.conf
```

Suchen Sie die beiden Zeilen `SSLCertificateFile` und `SSLCertificateKeyFile` und ändern Sie sie auf Ihre Dateien aus Schritt 3:

default-ssl.conf – nur diese zwei Zeilen ändern

```
SSLCertificateFile      /etc/ssl/certs/netconsult.crt
SSLCertificateKeyFile   /etc/ssl/private/netconsult.key
```

Speichern (Strg+O, Enter) und beenden (Strg+X).

Schritt 6 | HTTPS-Site aktivieren und Konfiguration prüfen

Aktivieren, testen, neu laden

```
sudo a2ensite default-ssl        # HTTPS-VirtualHost aktivieren
sudo apache2ctl configtest       # MUSS "Syntax OK" melden!
sudo systemctl reload apache2    # Konfiguration neu laden
```

✅ Regel
Vor jedem Reload/Restart: `apache2ctl configtest`. Meldet er einen Fehler, nennt er Datei und Zeile – erst beheben, dann neu laden.

Schritt 7 | Firewall: Port 443 freigeben

HTTPS-Port öffnen

```
sudo ufw allow 443/tcp           # HTTPS erlauben
sudo ufw status                  # Kontrolle: 80, 443 und 22 = ALLOW
```

Schritt 8 │ Test vom Host-Browser

1. Host-Browser öffnen: `https://[Server-IP]/netconsult/` (**https**, nicht http!).
2. Der Browser zeigt eine **Warnung** („Dies ist keine sichere Verbindung" / „Potenzielles Sicherheitsrisiko").
3. Klicken Sie auf **Erweitert** → **Risiko akzeptieren / Ausnahme hinzufügen** – die Seite erscheint.
4. Klicken Sie auf das Schloss-/Warn-Symbol neben der Adresse → Zertifikat anzeigen: Sie sehen **Ihr** Zertifikat (Aussteller = NetConsult GmbH).

> 📖 **Warum warnt der Browser?**
> Das Zertifikat ist **selbstsigniert** – es wurde nicht von einer vertrauenswürdigen Zertifizierungsstelle (CA) unterschrieben, der der Browser vertraut. Die **Verschlüsselung funktioniert trotzdem**; es fehlt nur der Identitätsnachweis durch eine CA. Für interne Testsysteme ist das in Ordnung – öffentliche Server nutzen CA-Zertifikate (z. B. Let's Encrypt, → LS07).

📸 **Screenshot 1: Browserwarnung (vor der Ausnahme)**	☐ erledigt
📸 **Screenshot 2: Zertifikatsdetails (Aussteller, Gültigkeit, SAN)**	☐ erledigt

Teil D – HTTP umleiten und TLS härten

Schritt 9 | HTTP automatisch auf HTTPS umleiten

HTTP-VirtualHost öffnen

```
sudo nano /etc/apache2/sites-available/000-default.conf
```

Fügen Sie **innerhalb** von `<VirtualHost *:80> … </VirtualHost>` diese Zeile ein:

Umleitung ergänzen

```
Redirect permanent / https://[Server-IP]/
```

Prüfen und neu laden

```
sudo apache2ctl configtest
sudo systemctl reload apache2
```

Test: Rufen Sie im Host-Browser `http://[Server-IP]/netconsult/` auf (http!) – der Browser muss automatisch auf `https://…` springen.

Schritt 10 | TLS härten: alte Protokolle abschalten

Alte TLS-/SSL-Versionen (SSLv3, TLS 1.0, TLS 1.1) gelten als unsicher. Schalten Sie sie zentral ab:

/etc/apache2/mods-available/ssl.conf – Zeile SSLProtocol anpassen

```
sudo nano /etc/apache2/mods-available/ssl.conf
# Zeile suchen und so aendern:
SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1
```

Prüfen und neu laden

```
sudo apache2ctl configtest
sudo systemctl reload apache2
```

> 💡 **Ergebnis**
> Der Server akzeptiert jetzt nur noch **TLS 1.2 und TLS 1.3** – der aktuelle Stand der Technik.

Schritt 11 | Abschluss-Dokumentation

HTTPS-URL der Seite	

Pfad Zertifikat (.crt)	
Pfad privater Schlüssel (.key)	
Erlaubte TLS-Versionen	
Funktioniert die HTTP→HTTPS-Umleitung?	☐ Ja ☐ Nein
Freigegebene Firewall-Ports	

> 💡 **Geschafft!**
> Ihr Webserver ist jetzt per HTTPS erreichbar, leitet HTTP automatisch um und akzeptiert nur moderne TLS-Versionen. Warum der Browser selbstsignierten Zertifikaten misstraut – und wie man mit Let's Encrypt kostenlose CA-Zertifikate bekommt – vertiefen Sie in den Informationsblättern und in LS07.